HUNT

PHP2SHELL AGENTIC OUTPUT MARKER HUNT

Exact machine-readable delimiters in endpoint command lines

CLASSIFICATION

Hunting query - Untested implementation sketch. Confidence Medium. Campaign-specific artifact.

PRIMARY PLATFORM

Microsoft Defender XDR Advanced Hunting. Required table: DeviceProcessEvents.

OPERATIONAL VALUE 7/10

Rapidly checks whether source-observed command-batch wrappers occurred on Defender-covered endpoints. It does not identify the PHP vulnerability or prove AI-directed activity.

Executive Assessment

What is known, what is inferred, and what remains unconfirmed

SOURCE FACT

Unit 42 observed post-exploitation command batches wrapped with section headers including ==SHELLUSER== and ==PASSWD==. The actor later accessed password hashes and MFA secrets and established an NTLM-relay tunnel.

VENDOR INTERPRETATION

Short serialized tasks, machine-readable output delimiters and quick pivots after failure were assessed as strong indicators of an agentic attacker.

DETECTION INFERENCE

If the wrapper text is passed in a process command line, Defender for Endpoint can retain it in DeviceProcessEvents.ProcessCommandLine. Exact marker matching is suitable for retrospective hunting.

ASSUMPTIONS AND LIMITS

Full command lines must be collected. The marker may be emitted inside an interpreter without appearing as a distinct child process. The actor can trivially change it. A match does not prove exploitation, credential theft, privilege escalation or attribution.

Threat Mechanics

Evidence-bounded sequence

01

PHP exploitation

Initial exploitation is reported; exploit-request telemetry is outside this hunt.

02

Command batching

Commands are issued in short serialized groups.

03

Output wrapping

Batches use machine-readable headers such as ==SHELLUSER== and ==PASSWD==.

04

Post-exploitation

The source reports credential access, NTLM relay and attempted Domain Admin escalation.

DETECTION BOUNDARY

This dossier detects only the exact wrapper artifacts when visible in process command lines. It intentionally does not reconstruct the wider intrusion chain.

Telemetry & Evidence Model

Required fields are documented in the Defender XDR schema

DeviceProcessEvents	**Required**	**Documented**	Process creation telemetry from Microsoft Defender for Endpoint.
ProcessCommandLine	**Required**	**Documented**	Command line used to create the new process.
Timestamp / DeviceId / DeviceName	**Required**	**Documented**	Event time and stable device investigation context.
FileName / FolderPath	**Required**	**Documented**	Created process identity and location.
InitiatingProcess*	**Enrichment**	**Documented**	Parent name, command line and account for triage.
ReportId	**Enrichment**	**Documented**	Use with DeviceName and Timestamp for event identity.

UNAVAILABLE IN THIS LOGIC

Exploit HTTP request, PHP runtime state, command output, proof of credential access, NTLM-relay success and Active Directory privilege changes.

Primary Hunting Query

Microsoft Defender XDR - exact marker search

```
DeviceProcessEvents
| where ProcessCommandLine has_any ("==SHELLUSER==", "==PASSWD==")
| project Timestamp, DeviceId, DeviceName, AccountDomain, AccountName,
          FileName, FolderPath, ProcessCommandLine,
          InitiatingProcessFileName, InitiatingProcessCommandLine,
          InitiatingProcessAccountName, ReportId
| order by Timestamp desc
```

CONDITION EVIDENCE

Both strings are explicitly reported by Unit 42 as section-header delimiters used by the observed attacker. No parent-process filter, threshold, rarity, aggregation or attribution condition is added.

STATUS

Hunting query - Untested implementation sketch. Validate syntax, retention, Linux/Windows command-line completeness and benign overlap in the target tenant.

Triage & Investigation

Treat a match as an artifact lead, not a verdict

1. Confirm raw event

Verify the full ProcessCommandLine and marker were not introduced by parsing, testing or a security product.

2. Establish provenance

Inspect process tree, account, web-server context, file origin and adjacent network activity.

3. Search both markers

Determine whether multiple wrapped sections occur on the same device and timeline without using an arbitrary alert threshold.

4. Scope impact

Review credential stores, MFA-secret access, NTLM relay evidence and AD group changes using independent telemetry.

5. Disposition

Benign simulation, expected automation, unresolved, or confirmed intrusion; never infer agentic AI solely from the marker.

CORRELATION KEY

Use DeviceId plus event time; ReportId is unique only with DeviceName and Timestamp. Do not correlate solely by filename or account.

False Positives & Validation

Promotion requires local evidence

EXPECTED OVERLAP

Penetration tests, purple-team emulation, copied research commands, incident-response scripts and bespoke automation that intentionally uses the same headers.

FAILURE CONDITIONS

Command-line truncation, disabled MDE sensor, unsupported workload, marker generated in-process, or telemetry outside retention.

01 Run query over retained endpoint data; record row count and endpoint coverage.

02 Inspect every match and label authorized tests or automation; do not pre-allowlist by filename.

03 Execute a controlled command containing each delimiter and confirm exact ProcessCommandLine retention.

04 Reject promotion if markers are absent during the controlled test or benign overlap dominates.

SUCCESS CRITERION

The controlled test is visible with complete marker text and real matches are sufficiently rare and triageable. Even then, keep as artifact hunting unless combined with independently validated behavior.

ATT&CK, Conclusion & References

Evidence-backed mapping and source record

MITRE ATT&CK T1059

Command and Scripting Interpreter. Directly supported by the observed execution of command batches. No credential-access or privilege-escalation sub-technique is assigned to the marker query itself.

CONCLUSION

A precise, low-complexity hunt is justified for the two exact delimiters. It is operationally useful for scoping the newly reported activity, but mutable and insufficient for alerting or attribution.

PRIMARY TECHNICAL RESEARCH

Unit 42. Threat Brief: Critical Vulnerabilities in PHP: CVE-2026-109618, CVE-2026-109619. Updated 23 October 2026, 12:30 PT.

hxxps://unit42[.]paloaltonetworks[.]com/cve-2026-109618-cve-2026-109619/

OFFICIAL SCHEMA

Microsoft Learn. DeviceProcessEvents table in the advanced hunting schema. Updated 7 August 2026.

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table

QUALITY CONTROLS

8 pages; defanged references; no customer data; exact artifacts only; documented fields; no arbitrary thresholds; no secondary-platform pseudorules.